Microsoft Purview Insider Risk Management

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview Insider Risk Management 5

The problem . . . 5

The solution . . . 5

How it works . . . 5

Why it matters . . . 6

Important boundaries . . . 6

Solution Overview — Microsoft Purview Insider Risk Management 6

What this solution delivers . . . 6

Insider Risk Management is HR/privacy-sensitive by design — read this first . . . 7

The IRM model — how the pieces fit . . . 7

The standard deployment model . . . 8

What's in the box . . . 8

Requirements — Microsoft Purview Insider Risk Management 9

R1. Insider Risk Management licensing (E5 / E5 Compliance / IRM add-on) . . . 9

R2. The Insider Risk Management role groups — configured for STRICT SEPARATION . . . 9

R3. Privacy / anonymization posture agreed and configured . . . 10

R4. In-scope indicators turned on globally . . . 10

R5. Endpoint (device) prerequisites for device indicators . . . 11

R6. HR connector (for departing-user / job-change triggers) . . . 11

R7. (Optional) Physical badging connector . . . 11

R8. Priority user groups and/or physical assets (if used) . . . 11

R9. HR, legal, privacy (and works-council / employee-relations) engagement and lawful basis . . . 11

R10. Pilot scope, analytics, and change control . . . 12

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 13

3. Security & Compliance PowerShell + Graph toolchain . . . 13

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 14

Implementation — Microsoft Purview Insider Risk Management 14

Phase 0 — Assess (confirm you can build safely) . . . 15

Phase 1 — Design (agree it with HR/legal, then name everything) . . . 15

Phase 2 — Configure the guardrails FIRST . . . 15

Phase 3 — Wire triggers and connectors . . . 17

Phase 4 — Pilot with analytics first, then a limited-scope policy . . . 17
Phase 5 — Validate (run the gates) . . . 18
Phase 6 — Operate the alert → case workflow (and hand off to HR/legal) . . . 18
Phase 7 — Expand (only after the gate passes) . . . 19
Testing & Validation — Microsoft Purview Insider Risk Management 19
Gate 1 — Role separation is clean (privacy control) . . . 19
Gate 2 — Anonymization is ON . . . 20
Gate 3 — Indicators, connectors, and integrations are ready . . . 20
Gate 4 — Each policy is On and healthy, scoped to the pilot . . . 20
Gate 5 — Analytics reviewed before reliance . . . 20
Gate 6 — A sanctioned test activity produces a scored alert . . . 20
Gate 7 — Alert triages and escalates into an audited case . . . 21
Gate 8 — HR/legal hand-off confirmed . . . 21
Gate 9 — Reporting rollup is coherent . . . 21
Troubleshooting — Microsoft Purview Insider Risk Management 21
Insider Risk Management doesn't appear in the portal / Settings won't open . . . 22
A policy is On but produces NO alerts . . . 22
HR connector shows no / stale data — departing-user detection silently stopped . . . 22
Device indicators never fire even though the user copied files . . . 22
Reviewers see real names when they shouldn't (or "why is everyone anonymized?") . . . 23
An account can both build policies and unmask identities (separation broken) . . . 23
"Access denied" triaging alerts or opening a case . . . 23
Alerts are overwhelming / lots of false positives in the pilot . . . 23
Analytics shows nothing / won't run . . . 23
Security-policy-violation policy never triggers . . . 24
`Get-InsiderRiskPolicy` / IRM cmdlets aren't recognized . . . 24
`PURVIRM-Report.ps1` returns no records . . . 24
Connect-IPPSSession / Connect-MgGraph fails . . . 24
Best Practices — Microsoft Purview Insider Risk Management 25
Privacy first — always . . . 25
Role separation — enforce it, then watch it . . . 25
Determinations stay with HR/legal . . . 25
Pilot and tune before you rely . . . 26
Detection hygiene . . . 26
Operations and evidence integrity . . . 26
Change control and safety . . . 26

Fit with the rest of Purview 27
Deliverables Summary — Microsoft Purview Insider Risk Management 27
Documentation 27
PowerShell tools (5) 28
Named objects (verbatim — used across docs, scripts, and tests) 29
What this solution deliberately does NOT do 29
Appendix A — PowerShell Scripts 30

Executive Summary — Microsoft Purview Insider Risk Management

The problem

The most damaging data loss usually comes from **inside** — a departing employee taking files on their way out, a well-meaning person leaking data by accident, or a user who repeatedly circumvents controls. These events are hard to see because the people involved **already have legitimate access**. Left unaddressed, they cost intellectual property, customer trust, and regulatory standing. Addressed clumsily — with blanket employee surveillance — they cost something else: employee trust, and potentially compliance with privacy and labour law.

The solution

This solution implements **Microsoft Purview Insider Risk Management (IRM)** the responsible way. It detects risky insider activity from signals your Microsoft 365 tenant already produces, using Microsoft's policy templates — **Data theft by departing users**, **Data leaks**, and **Security policy violations** — and it does so **with privacy guardrails and HR/legal in the loop**:

- **Privacy by design.** Usernames are **anonymized (pseudonymized)** for reviewers by default;

identity is revealed only when justified, role-permitted, and **audited**. Policies are scoped to the **minimum** population needed.

- **Strict role separation.** The people who **build policies** (Admins), **triage and investigate**

(Analysts/Investigators), and **audit the reviewers** (Auditors) are deliberately kept separate, using purpose-built role groups — so no one both defines risk and unmasks identity unchecked.

- **Determinations stay with HR/legal.** IRM produces **evidence and an audited case trail**; whether

an alert reflects misconduct, and what the consequence is, is an **HR/legal determination** — never a technical default and never the administrator's call.

The result is a governed, defensible insider-risk program: detected, triaged into cases, evidence routed to the right people — **without overreach**.

How it works

We follow a repeatable model — **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** — that configures the **privacy and role-separation guardrails first**, then turns on indicators, builds the three policies from templates, wires the **HR connector** (the departing-user trigger) and, where used, a **physical badging connector**, and runs **Insider Risk analytics** and a **pilot scope** before anyone relies on alerts. Every high-impact change is piloted and reversible.

The solution ships as **self-guided documentation plus five PowerShell tools** (Security & Compliance PowerShell / Graph) that assess role separation and privacy settings, validate policy prerequisites, check connector/indicator readiness, produce a leadership rollup, and stage scope expansion — all **read-only or preview-by-default**, with **no credentials in code**.

Why it matters

• **See the inside threat** — departing-user theft, inadvertent leaks, repeat violations — instead of finding out after the damage is done.

• **Respect privacy and the law** — anonymization, minimal scope, and separated duties, engaged with HR/legal/privacy from the start.

• **Defensible evidence, clear ownership** — an audited alert→case trail, with the **determination in the right hands**.

• **A fraction of consulting cost** — the same disciplined method a specialist would use, delivered as a repeatable, tested runbook.

Important boundaries

Insider Risk Management is **licensing-dependent** (Microsoft 365 E5 / E5 Compliance / IRM add-on; some capabilities are additional or in preview) and the Purview portal is **evolving** — capability availability should be **verified against your licensing and tenant**. IRM **monitors people**: in many jurisdictions this requires notice, consultation, or a specific **lawful basis** before it is enabled — that applicability is a **legal determination** for your organization, and this solution provides the technical method and guardrails, not the legal decision. Investigative and disciplinary **outcomes remain with HR/legal**.

Solution Overview — Microsoft Purview Insider Risk Management

What this solution delivers

Most catastrophic data loss does not come from an outside attacker — it comes from **someone who already has access**: an employee packing up their OneDrive on the way out the door, a well-meaning person emailing a customer list to a personal account, or a user who keeps circumventing the controls you put in place. **Microsoft Purview Insider Risk Management (IRM)** is the compliance-side capability that detects these patterns from the signals your tenant already produces — and does it **with privacy guardrails and HR/legal in the loop**, so you manage risk without turning the workplace into a surveillance program.

This solution walks a competent-but-novice administrator through a **complete, repeatable IRM deployment**:

1. **Configure the privacy-by-design guardrails and role separation first** — anonymization (pseudonymization) of usernames, and the strict split between the people who *build policies* (Admins), the people who *triage and investigate* (Analysts/Investigators), and the people who *audit the reviewers* (Auditors). This is deliberately **step one**, not an afterthought.

1. **Build policies from Microsoft's templates** — **Data theft by departing users**, **Data leaks**,

and **Security policy violations** — naming every policy, indicator, and scope, and always **piloting in analytics/limited scope before you rely on alerts**.

1. **Wire the triggering events and connectors** — the **HR connector** (resignation / termination / job-level signals) and, where used, the **physical badging connector** — plus the **indicators** (Office, device/endpoint, cloud, Defender) that give a policy something to detect.

1. **Operate the alert → case workflow** — triage the alert queue, escalate real signals into **cases**, and hand **investigative and disciplinary outcomes to HR/legal**. IRM gives you the technical evidence and the audited workflow; **it does not make the employment decision**.

Together these turn a **blind spot** (no visibility into departing-user data theft, inadvertent leaks, or repeat policy violations) into a **governed, defensible, privacy-respecting insider-risk program** — proven in analytics and a pilot scope before it drives real cases.

Insider Risk Management is HR/privacy-sensitive by design — read this first

IRM is not a normal Purview workload. It looks at **people's activity**, so it carries employee-privacy, works-council, labour-law, and data-protection obligations that a DLP or retention project does not. This solution is built around three non-negotiable principles, and every step reflects them:

• **Privacy by design.** IRM **anonymizes (pseudonymizes) usernames by default** in the analyst experience — reviewers see coded identifiers, not names, until there is a justified, role-gated, **audited** reason to reveal identity. You keep anonymization **on** unless HR/legal/privacy have explicitly agreed otherwise in writing. Scope policies to the **minimum** population needed.

• **Strict role separation.** The person who **defines** what counts as risky (Admin) must not be the same person who **decides who did it** (Investigator), and both are watched by an independent **Auditor**. Purview provides purpose-built role groups precisely so these duties can be separated — this solution configures them that way and treats any overlap as a finding.

• **Determinations belong to HR/legal.** IRM produces **signals, alerts, evidence, and an audited case trail**. **Whether an alert reflects misconduct, and what the consequence is, is an** HR/legal/privacy determination** — never a technical default and never made by the administrator. The tooling stops at "here is the evidence, routed to the right reviewers"; the outcome is theirs.

> ***Deploy this with your HR, legal, privacy, and (where applicable) works-council / employee-relations stakeholders — not around them.*** *Several regions require notice, consultation, or a lawful basis before monitoring employee activity. Confirm your obligations before you enable a single policy. This solution provides the technical method and the guardrails; the* ***applicability and lawful basis are a legal determination*** *(see* `global-requirements-purview.md` *§5).*

The IRM model — how the pieces fit

• **Policy templates** are Microsoft-provided starting points that pre-select the right detections for a scenario. The three this solution builds: **Data theft by departing users**, **Data leaks**, and **Security policy violations**. (Others exist — data leaks by priority/risky users, risky AI usage, risky browser usage, patient-data misuse, forensic evidence — noted where relevant; the three above are the core.)

• **Indicators** are the individual risky activities a policy can watch — e.g. downloading from SharePoint, copying files to USB or personal cloud, printing, emailing to an external/personal recipient, or a Defender for Endpoint alert. Indicators must be **turned on globally** before a policy can use them, and several (device/endpoint indicators, healthcare, physical) have their own prerequisites.

• **Triggering events** are what makes a user *in scope* for a policy's detection window. For **data theft by departing users **the trigger is a** resignation/termination date **(from the HR connector) or an** Entra account deletion**; for** data leaks **it is a** DLP policy match **(or exfiltration activity); for** security policy violations **it is a** Defender for Endpoint** alert. No trigger, no scoring.

• **Connectors** bring in signals Purview does not natively have: the **HR connector** (the leaver / job-change dates that drive departing-user policies) and the **physical badging connector** (badge-in/out, used to correlate after-hours or post-resignation building access). These are **CSV/API data connectors**, set up in the portal.

• **Risk scoring** → **alerts.** Scored activity that exceeds thresholds raises **alerts** in a queue, with a severity. **Analytics** (an opt-in, aggregate, no-policy scan) lets you see where risk concentrates **before** you commit to policies.

• **Alerts** → **cases.** An analyst **triages** each alert (confirm / dismiss / resolve). A confirmed, meaningful alert is escalated into a **case** — the investigation container with the user's scored activity, notes, and case actions (notify, escalate to eDiscovery / Communication Compliance, resolve). Cases are where **Investigators** work and where the **HR/legal hand-off** happens.

The design principle across all of it: **detect the minimum, reveal the minimum, and separate who does what** — visibility with guardrails, not surveillance.

The standard deployment model

Every step follows the same repeatable model, with an explicit **pass/fail gate** between phases:

Assess → **Design** → **Configure** → **Pilot (analytics / limited scope)** → **Validate** → **Expand (enforce).**

• **Assess** — confirm licensing (E5 / E5 Compliance / IRM add-on), the IRM role groups and their separation, portal access, the in-scope indicators/connectors, and **the HR/legal/privacy sign-off**.

• **Design** — agree the anonymization posture, the policy scope (which users), the templates, the indicators, and the triggers **with HR/legal**. Name every object.

• **Configure** — set global privacy + role separation **first**, turn on indicators, build the three policies from templates, wire the HR (and physical) connector.

• **Pilot** — run **Insider Risk analytics** and/or a **limited-scope** policy first; tune thresholds and exclusions before you rely on alerts.

• **Validate** — run the pass/fail gates in `05-testing.md`.

• **Expand** — widen scope only after the gate passes and HR/legal confirm the workflow.

What's in the box

• This overview, a **Requirements** guide, an ordered **Implementation** guide, **Testing** (pass/fail gates), **Troubleshooting**, **Best Practices**, and a **Deliverables Summary** + **Executive Summary**.

• **Five PowerShell tools** (Security & Compliance PowerShell / Graph): an IRM readiness + role-separation + privacy-settings **assessment**, a **policy-from-template configuration helper**, a **connector/indicator readiness checker**, an **alert/case rollup report**, and a **scope/config helper** — read-only or `-WhatIf` by default; **no credentials in code**.

> ***Sources:*** *Microsoft Learn — *Insider risk management* (overview, settings, policies, policy templates, indicators, HR connector, analytics, alerts, cases, roles/permissions). Insider Risk Management is* ***licensing-dependent*** *(Microsoft 365 E5 / E5 Compliance / Insider Risk Management add-on; some capabilities are additional or in preview) and the portal is* ***evolving*** *—* ***verify capability availability against your licensing/tenant*** *rather than assuming.*

Requirements — Microsoft Purview Insider Risk Management

Confirm every prerequisite below **before** you configure anything. Category-level prerequisites (tenant, licensing model, least-privilege roles, S&C PowerShell / Graph toolchain, in-scope data sources, compliance/privacy/legal stakeholders, pilot scope + change control) are in `global-requirements-purview.md` — reference them; they are **not** repeated here. The items below are the ones **specific to Insider Risk Management**, especially its **role separation** and **privacy** prerequisites.

Each requirement is written as **Description · Why · Verify · Implement if missing.**

> *Insider Risk Management is* ***HR/privacy-sensitive****. Several requirements below are* ***organizational, not technical*** *(HR/legal engagement, lawful basis, works-council consultation). Treat those as hard gates: they must be satisfied before you enable a policy, and their determination is* ***not yours to make*** *— see* `global-requirements-purview.md` *§5.*

R1. Insider Risk Management licensing (E5 / E5 Compliance / IRM add-on)

Description: Microsoft 365 **E5**, the **E5 Compliance** add-on, or the standalone **Insider Risk Management** add-on assigned to the users who will be **in scope** of policies (and to the priority users if used). Some capabilities — **forensic evidence**, **Adaptive Protection**, healthcare (**patient data misuse**) — carry additional or preview requirements. **Why:** IRM is a premium, plan-gated compliance capability; without the right licence the policies and several indicators/connectors are unavailable, and scored users must be licensed. **Verify:** Microsoft 365 admin center → **Billing** → **Licenses** — confirm E5 / E5 Compliance / IRM. In the Purview portal, **Insider Risk Management** appears in the left navigation and lets you open **Settings**. Cross-check any advanced feature against the *Microsoft Purview service description* — **verify against your licensing/tenant**, do not assume. **Implement if missing:** Acquire and assign the appropriate SKU/add-on to in-scope (and priority) users before authoring policies.

R2. The Insider Risk Management role groups — configured for STRICT SEPARATION

Description: The purpose-built IRM role groups assigned so that **duties are separated**, not concentrated in one account:

• **Insider Risk Management Admins** — create/configure **policies and settings**; **cannot** see alert/case user activity.

• **Insider Risk Management Analysts** — **triage and investigate** alerts/cases; see the **anonymized** experience unless de-anonymization is justified and role-permitted.

• **Insider Risk Management Investigators** — full case investigation including **content/forensic detail and de-anonymized identity** where justified.

• **Insider Risk Management Auditors** — view the **IRM audit log** (who reviewed/unmasked what) — the independent watch on the reviewers.

• **Insider Risk Management** (the combined "everything" role group) — **avoid** assigning it to real operators in production; it defeats separation. Use the granular groups. **Why:** Role separation is the core privacy control: the person who **defines** risk must not be the person who **unmasks** identity, and both must be **independently audited**. Concentrating roles is a governance failure and, in many regions, a compliance one. **Verify:** Purview portal → **Settings** → **Roles & scopes** → **Permissions** (or **Roles & scopes**), or run `PURVIRM-Discovery.ps1` — confirm each role group has the **right, minimal** membership and that **no single person holds a conflicting combination** (e.g. Admin **and** Investigator). **Implement if missing:** Assign the least-privilege IRM role groups under change control, mapping named people to **one** function each. Record the mapping with HR/legal.

R3. Privacy / anonymization posture agreed and configured

Description: A decision — **made with privacy/HR/legal** — on IRM **global privacy settings**, specifically **anonymization (pseudonymization) of usernames** in the analyst experience, kept **ON** by default, with de-anonymization treated as a justified, role-gated, audited exception. **Why:** Anonymization is what lets you detect risk **without** exposing employee identity to reviewers by default; turning it off changes the privacy and legal posture of the whole program. **Verify:** Purview portal → **Insider Risk Management** → **Settings** → **Privacy** — confirm **"Show anonymized versions of usernames"** is selected. `PURVIRM-Discovery.ps1` flags the posture to confirm in-portal (the privacy setting is portal-managed). **Implement if missing:** Set anonymization **on** and document who may de-anonymize, on what basis, with what approval. Do **not** disable anonymization without written privacy/legal agreement.

R4. In-scope indicators turned on globally

Description: The **indicators** the three policies need, enabled under **Settings** → **Policy indicators**: **Office indicators** (SharePoint download, file sharing, email exfiltration), **Device indicators** (copy to USB/personal cloud, print, etc. — requires endpoint prerequisites), **cloud service** indicators, and **Microsoft Defender for Endpoint** indicators (for security-policy violations). **Why:** A policy can only detect activities whose **indicators are enabled**; indicators are a **global** switch that policies then draw from. **Verify: Settings** → **Policy indicators** — confirm the needed families are checked. Device indicators additionally require the endpoint prerequisites in R5. **Implement if missing:** Enable the indicator families your chosen templates require (see `03-implementation.md` for the exact set per policy).

R5. Endpoint (device) prerequisites for device indicators

Description: For **device/endpoint indicators**, devices **onboarded** to Microsoft Purview (endpoint DLP onboarding, which uses the same onboarding as Microsoft Defender for Endpoint) and running a supported OS. **Why:** Device indicators (USB copy, print, copy-to-cloud) only fire from **onboarded** devices; un-onboarded endpoints are invisible to IRM. **Verify:** Purview portal → **Settings** → **Device onboarding** shows onboarded devices; a test device appears in endpoint DLP activity. `PURVIRM-Test-Readiness.ps1` reports whether device indicators are enabled and points you to the onboarding check. **Implement if missing:** Onboard the in-scope devices before relying on device indicators. Until then, device-based detections will not fire.

R6. HR connector (for departing-user / job-change triggers)

Description: The **Microsoft 365 HR connector** importing **resignation/termination dates** (and, optionally, job-level changes and performance signals) from your HR system — the **triggering event** for **Data theft by departing users**. **Why:** The departing-user template scopes a user for detection based on their **leaver date**; without the HR connector (or Entra account deletion) there is no trigger and the policy scores no one. **Verify:** Purview portal → **Settings** → **Data connectors** (or **Data connectors** in the M365 admin center) — the HR connector shows **recent successful uploads**. `PURVIRM-Test-Readiness.ps1` reports connector presence/freshness where readable. **Implement if missing:** Create the HR connector (Entra app registration + the CSV/API upload Microsoft documents) and schedule regular uploads. **Alternative trigger:** Entra **account deletion** can trigger the departing-user policy without an HR feed, at coarser fidelity.

R7. (Optional) Physical badging connector

Description: The **physical badging connector** importing **badge access** events, used to correlate physical access (e.g. after-hours or post-resignation building entry) with digital exfiltration signals. **Why:** Some departing-user / data-theft scenarios are strengthened by physical-access indicators; these require the badging feed. **Verify: Settings** → **Data connectors** shows the physical badging connector with recent uploads; **Settings** → **Policy indicators** shows physical-access indicators available. **Implement if missing:** Only configure if your scenario needs physical correlation and you have a badging system that can export the required schema. It is **optional**; the core three policies do not depend on it.

R8. Priority user groups and/or physical assets (if used)

Description: Where risk is concentrated in specific populations (executives, admins, R&D) or assets, **priority user groups** (and priority physical assets) defined under **Settings**, so higher-sensitivity templates or scoping can target them. **Why:** Priority-user templates and boosted scoring depend on these groups existing; they also help you scope narrowly (privacy). **Verify: Settings** → **Priority user groups** — confirm the groups and their membership are correct. **Implement if missing:** Define priority user groups **with HR/legal** (membership in a "priority" group is itself sensitive) before using priority-user templates.

R9. HR, legal, privacy (and works-council / employee-relations) engagement and lawful basis

Description: Named, engaged stakeholders from **HR, legal, privacy**, and — where applicable — **works councils / employee representatives**, plus a documented **lawful basis / notice / consultation** for monitoring employee activity in your jurisdiction(s). **Why:** IRM monitors people. In many regions this **requires** notice, consultation, or a specific lawful basis **before** you switch it on; the **applicability is a legal determination**, and case outcomes are **HR/legal's**, not the administrator's. **Verify:** Confirm the named stakeholders, the recorded lawful basis / notice, and the agreed anonymization and de-anonymization rules **in writing** before enabling any policy. **Implement if missing: Stop** and obtain them. This is a hard gate — do not enable IRM policies without it. (See `global-requirements-purview.md` §5.)

R10. Pilot scope, analytics, and change control

Description: A **named pilot scope** (a limited user group) and agreement to **run Insider Risk analytics** and/or a limited-scope policy first, under a **change-control** process, before any tenant-wide policy. **Why:** IRM thresholds and exclusions need **tuning against real activity**; analytics and a pilot prevent alert floods and false positives from undermining the program (and from unfairly flagging people). Analytics is aggregate and requires **no policy**, making it the safest first look. **Verify:** Confirm the pilot group, that **Analytics** is available in the portal, and a change window/ approval path. `PURVIRM-Set-Scope.ps1` (`-WhatIf`) previews pilot-group scoping. **Implement if missing:** Define the pilot group and run **Analytics** first; agree change control before expanding scope.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

- **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.
- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.
- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.
- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

Implementation — Microsoft Purview Insider Risk Management

This is the ordered, do-this-then-that guide. It follows the standard model (**Assess** → **Design** → **Configure** → **Pilot (analytics / limited scope)** → **Validate** → **Expand**) and — because IRM is HR/privacy-sensitive — it **configures the privacy guardrails and role separation FIRST**, before any policy exists. Every object is named verbatim so the scripts, testing, and troubleshooting line up. Replace the `contoso.com` / sample group names with your own.

> ***Portal note.*** *IRM policy authoring is done in the **Microsoft Purview portal** (`purview.microsoft.com` → **Insider Risk Management**). PowerShell (Security & Compliance PowerShell / Graph) is used here for **readiness, role/scope verification, and reporting** — not to invent a policy-authoring path IRM does not expose. Where a portal path or capability may differ by tenant/licence, **verify against your licensing/tenant**.*

> ***Hard gate before you start.*** *Do **not** begin Phase 2 until Requirement **R9** (HR/legal/privacy engagement + lawful basis + agreed anonymization rules) is satisfied **in writing**. IRM monitors people; the applicability is a legal determination, not a technical one.*

Phase 0 — Assess (confirm you can build safely)

1. **Confirm licensing (R1).** Verify E5 / E5 Compliance / IRM add-on is assigned to in-scope (and priority) users. IRM appears in the Purview left navigation.

1. **Confirm role separation (R2).** Run `PURVIRM-Discovery.ps1` (read-only). Confirm the four functional role groups exist with minimal, correct membership, and that **no person holds a conflicting combination** (Admin + Investigator, etc.). The combined **Insider Risk Management** role group should **not** be assigned to production operators.

• **Gate 0a:** role separation clean → continue. Overlap → fix membership **before** proceeding.

1. **Confirm privacy posture (R3).** In **Insider Risk Management** → **Settings** → **Privacy**, confirm **"Show anonymized versions of usernames"** is selected. `PURVIRM-Discovery.ps1` flags this to confirm in-portal.

• **Gate 0b:** anonymization **on** (or an explicit, written privacy/legal exception) → continue.

1. **Confirm the toolchain** (`global-requirements-purview.md` §3): `Connect-IPPSSession`, `Connect-ExchangeOnline`, and `Connect-MgGraph` all succeed with an MFA-capable admin.

Phase 1 — Design (agree it with HR/legal, then name everything)

Decide and **record with HR/legal/privacy**:

• **Anonymization:** ON (default). Document **who** may de-anonymize, **on what basis**, with **what approval**, and that every de-anonymization is** audited**.

• **Scope:** the **minimum** population for each policy. Use a named pilot group first: `SG-IRM-Pilot`.

• **The three policies** and their verbatim names:

• `IRM-DepartingUser-DataTheft` — template **Data theft by departing users**.

• `IRM-DataLeaks-General` — template **Data leaks**.

• `IRM-SecurityPolicyViolations` — template **Security policy violations**.

• **Indicators** each policy needs (Phase 3.2).

• **Triggers:** HR-connector leaver date (departing user), DLP match (data leaks), Defender for Endpoint alert (security policy violations).

• **Priority user groups** (if used): `PUG-Executives`, `PUG-Privileged-Admins` — defined with HR/legal.

Phase 2 — Configure the guardrails FIRST

2.1 Role separation (do this before policies exist)

In **Settings** → **Roles & scopes** → **Permissions** (or Purview **Roles & scopes**), assign named people to **one** function each:

Function	Role group	Sees identity?	Purpose
Build policies/settings	**Insider Risk Management Admins**	No	Configure policies/indicators/connectors
Triage & investigate	**Insider Risk Management Analysts**	Anonymized by default	Work the alert/case queue
Deep investigate	**Insider Risk Management Investigators**	De-anonymized where justified	Case + content/forensic detail
Audit the reviewers	**Insider Risk Management Auditors**	n/a (audit log only)	Independent oversight

- **Do not** assign the combined **Insider Risk Management** role group to operators.
- **Pass/fail:** re-run `PURVIRM-Discovery.ps1` — separation clean, no conflicting combinations.
- **Rollback:** remove any mis-assigned membership; role groups are additive and safe to correct.

2.2 Privacy and global settings

In **Insider Risk Management** → **Settings**:

- **Privacy** → **Show anonymized versions of usernames** (ON).
- **Policy indicators** → enable the families the three policies need (2 below references these).
- **Policy timeframes** → set the **activation window** (detection window after a trigger, e.g. 30 days) and **past activity** (look-back, e.g. 90 days) per your HR/legal agreement.
- **Intelligent detections** → keep default alert-volume and file-type exclusions; note MDLP alert import if you use endpoint DLP.
- **Priority user groups** → create `PUG-*` groups only if used (with HR/legal).
- **Analytics** → ensure Analytics is enabled (used in Phase 4).

2.3 Turn on indicators (global switch policies draw from)

Under **Settings** → **Policy indicators**, enable at least:

- **Office indicators:** SharePoint download, file shared externally, email sent to external/personal recipient. *(Data theft by departing users; Data leaks.)*
- **Device indicators:** file copied to USB/removable media, file copied to personal cloud, file printed, file downloaded from cloud to device. *(Requires device onboarding — R5. Data theft; Data leaks.)*
- **Microsoft Defender for Endpoint indicators.** *(Security policy violations — requires the MDE integration/connection.)*
- **Cumulative exfiltration detection / sequence detection** (risk boosters) as agreed.

Phase 3 — Wire triggers and connectors

3.1 HR connector (departing-user / job-change trigger)

1. **Settings** → **Data connectors** (or M365 admin center → **Data connectors**) → create the **HR connector**.

1. Register the **Entra app** the connector requires, note the **connector job ID**, and configure the **CSV/API upload** Microsoft documents (resignation date, termination date, and optionally job-level change). **No secrets in scripts** — the upload credential lives in the connector app, not in code.

1. Schedule regular uploads and confirm the connector shows **recent successful ingestion**.

2. **Alternative trigger:** if you have no HR feed, the departing-user policy can trigger on **Entra account deletion** — coarser, but no connector required.

• **Pass/fail:** `PURVIRM-Test-Readiness.ps1` reports connector presence/freshness; portal shows a recent successful upload.

3.2 (Optional) Physical badging connector

Only if your scenario needs physical correlation (R7): create the **physical badging connector** and confirm physical-access indicators appear under **Policy indicators**. Skip otherwise.

3.3 Defender for Endpoint connection (for security-policy-violation triggers)

Confirm the **Microsoft Defender for Endpoint** connection/integration is enabled so its alerts can act as the **trigger** and **indicator** source for `IRM-SecurityPolicyViolations`. Verify in the Purview IRM indicator settings and the Defender portal.

Phase 4 — Pilot with analytics first, then a limited-scope policy

4.1 Run Insider Risk analytics (no policy, aggregate, safest first look)

1. **Insider Risk Management** → **Analytics** → **run scan** (opt-in). Analytics evaluates aggregate risk **without a policy and without naming individuals**, so you learn *where* risk concentrates and *which templates matter* before scoping anyone.

1. Review the analytics report with HR/legal to size the program.

• **Gate 4a:** analytics completed and reviewed → proceed to a scoped policy.

4.2 Build the three policies from templates — scoped to the pilot group

For each policy, **Insider Risk Management** → **Policies** → **Create policy**, choose the template, and scope to `SG-IRM-Pilot` only:

1. `IRM-DepartingUser-DataTheft` — template **Data theft by departing users**.

• Trigger: HR-connector leaver date (or Entra account deletion).

• Indicators: Office + device exfiltration indicators (2.3).

• Scope: `SG-IRM-Pilot`.

1. `IRM-DataLeaks-General` — template **Data leaks**.

• Trigger: **DLP policy match** (select the DLP policy whose high-severity matches should trigger

IRM; if you have none, create/point to a baseline DLP policy first) or exfiltration activity.

• Indicators: Office + device exfiltration indicators.

• Scope: `SG-IRM-Pilot`.

1. `IRM-SecurityPolicyViolations` — template **Security policy violations**.

• Trigger: **Microsoft Defender for Endpoint** alert.

• Indicators: Defender for Endpoint indicators.

• Scope: `SG-IRM-Pilot`.

• **Pilot rule:** keep scope at `SG-IRM-Pilot`; leave default thresholds initially. **Do not** widen scope yet.

• **Pass/fail:** each policy shows **Status = On** and **healthy** (no configuration warning) in the policy list. `PURVIRM-Set-PolicyFromTemplate.ps1 -WhatIf` validates prerequisites and prints the intended configuration/plan before you build in the portal.

Phase 5 — Validate (run the gates)

Work the gates in `05-testing.md`:

• Role separation clean (no conflicting combinations).

• Anonymization **on** in the analyst experience.

• Indicators enabled; HR connector fresh; MDE connected.

• Each policy **On + healthy**, scoped to pilot.

• A **test exfiltration** by a pilot user (e.g. copying a benign file to USB on an onboarded device, in a **sanctioned test**) produces a **scored activity** → **alert** within the detection window.

• The alert can be **triaged** and **escalated into a case**, and the case shows the **audited** reviewer trail.

• **Do not proceed to Expand until every gate passes** and HR/legal confirm the alert→case→hand-off workflow is acceptable.

Phase 6 — Operate the alert → case workflow (and hand off to HR/legal)

1. **Triage** (Analyst): review the alert queue; for each alert **confirm** (real risk) or **dismiss** (benign), with a note. Reviewers see the **anonymized** experience by default.

1. **Escalate to a case** (Analyst/Investigator): confirmed, meaningful alerts become **cases** — the investigation container with the user's scored activity, notes, and case actions.

1. **Investigate** (Investigator): where justified and role-permitted, view content/forensic detail and **de-anonymize identity** — this action is **audited** (Auditors can see it).

1. **Case actions:** send a **notification** (policy-tip / reminder), **escalate to eDiscovery** or

Communication Compliance, or **resolve**. **Determination and any disciplinary outcome are HR/legal's** — IRM routes evidence to them; it does not decide.

1. **Audit** (Auditor): periodically review the **IRM audit log** to confirm reviewers acted within policy (especially de-anonymizations).

Phase 7 — Expand (only after the gate passes)

Widen scope **deliberately** — group-by-group, not tenant-wide in one move — using `PURVIRM-Set-Scope.ps1` (`-WhatIf` first) to stage `SG-IRM-Pilot` → broader groups. Re-run the gates after each expansion. Keep anonymization on and role separation intact as you scale.

Rollback summary

Change	Rollback
Role assignment error	Remove the mis-assigned member from the role group (additive, safe).
Policy too noisy in pilot	Set policy **Status = Off**, tune thresholds/exclusions, re-pilot.
Anonymization mis-set	Re-select **Show anonymized versions of usernames** (Settings → Privacy).
Scope expanded too far	Remove the added members from the scope group (`PURVIRM-Set-Scope.ps1`).
HR connector bad data	Pause uploads, correct the source export, re-upload; trigger re-evaluates.

> ***Never** delete cases or audit records to "clean up" — they are the defensible, HR/legal-facing evidence trail. Retention/disposition of IRM records is a **records/legal determination**.*

Testing & Validation — Microsoft Purview Insider Risk Management

Run these gates in order. Each has an explicit **pass/fail** signal. **Do not expand scope** (Phase 7) until every gate passes **and** HR/legal have confirmed the alert→case→hand-off workflow is acceptable. Where a test involves a real user's activity, use a **sanctioned test account/action** with HR/legal awareness — do not covertly test on a real employee.

Use the scripts where noted; they are read-only or `-WhatIf` and change nothing you don't approve.

Gate 1 — Role separation is clean (privacy control)

Why: The person who defines risk must not be the person who unmasks identity; both must be independently audited. **How:** Run `PURVIRM-Discovery.ps1`. Review the role-group membership table. **Pass:** The four functional groups (**Admins / Analysts / Investigators / Auditors**) have minimal, correct

membership; **no single person holds a conflicting combination** (e.g. Admin **and** Investigator); the combined **Insider Risk Management** role group is **not** assigned to operators. **Fail:** Any conflicting combination, or over-broad membership → fix in **Roles & scopes** before continuing.

Gate 2 — Anonymization is ON

Why: Reviewers must see pseudonymized identities by default. **How:** Purview → **Insider Risk Management** → **Settings** → **Privacy**; `PURVIRM-Discovery.ps1` flags the posture to confirm in-portal. **Pass: "Show anonymized versions of usernames"** is selected; the analyst experience shows coded identifiers, not names. **Fail:** Anonymization off without a **written** privacy/legal exception → re-enable it.

Gate 3 — Indicators, connectors, and integrations are ready

Why: A policy can only detect what its indicators/triggers can see. **How:** Run `PURVIRM-Test-Readiness.ps1`; cross-check in **Settings** → **Policy indicators / Data connectors / Device onboarding**. **Pass:** The required **indicator families are enabled**; **device onboarding** shows onboarded devices (for device indicators); the **HR connector** shows a recent successful upload (or you are deliberately using the Entra-account-deletion trigger); **Defender for Endpoint** is connected (for security-policy violations). **Fail:** A needed indicator is off, no devices onboarded, HR connector stale, or MDE not connected → fix the specific prerequisite (see `02-requirements.md` R4–R6 and `03-implementation.md` Phase 3).

Gate 4 — Each policy is On and healthy, scoped to the pilot

Why: Misconfigured or over-scoped policies produce noise or over-collection. **How:** Purview → **Insider Risk Management** → **Policies**; `PURVIRM-Set-PolicyFromTemplate.ps1 -WhatIf` to re-validate prerequisites/plan. **Pass:** `IRM-DepartingUser-DataTheft`, `IRM-DataLeaks-General`, and `IRM-SecurityPolicyViolations` each show **Status = On** and **healthy** (no configuration warning), scoped to `SG-IRM-Pilot` only. **Fail:** Any policy shows a health/configuration warning, or is scoped beyond the pilot → correct before testing detections.

Gate 5 — Analytics reviewed before reliance

Why: Analytics sizes the program and tunes expectations **without** naming individuals. **How: Insider Risk Management** → **Analytics** → run scan; review with HR/legal. **Pass:** Analytics scan completed and the report reviewed with HR/legal. **Fail:** No analytics run before scoping → run it first.

Gate 6 — A sanctioned test activity produces a scored alert

Why: Proves the end-to-end detection path (trigger → indicator → score → alert) actually works. **How:** With a **pilot test account** that is **in scope** and (for the departing-user policy) marked as a leaver in the HR feed, perform a **benign, sanctioned** exfiltration action on an **onboarded** device — e.g. copy a harmless test file to removable media, or email a test file to an external test address — within the detection window. **Pass:** The activity appears as **scored activity** and raises an **alert** in the queue with a severity, within the policy's activation window. **Fail:** No alert after the detection window → check the trigger fired (leaver date / DLP match / MDE alert), the indicator is enabled, and the device is onboarded (Gate 3).

Gate 7 — Alert triages and escalates into an audited case

Why: The operational workflow and the audit trail are the point. **How:** As an **Analyst**, triage the Gate-6 alert (confirm), then escalate to a **case**. As an **Auditor**, check the IRM audit log. **Pass:** The alert can be **confirmed/dismissed** with a note; a confirmed alert becomes a **case**; any **de-anonymization** in the case is recorded in the **IRM audit log** (visible to Auditors). **Fail:** Cannot triage/escalate (likely a role issue — Gate 1), or reviewer actions are not audited → re-check role assignments and settings.

Gate 8 — HR/legal hand-off confirmed

Why: Determinations are theirs, not the administrator's. **How:** Walk the case workflow with HR/legal; confirm they accept how evidence is routed (notification / eDiscovery / Communication Compliance / resolve) and who decides outcomes. **Pass:** HR/legal confirm the hand-off is acceptable and the **determination/outcome sits with them**. **Fail:** Ambiguity about who decides outcomes → resolve **before** expanding scope.

Gate 9 — Reporting rollup is coherent

Why: Leadership needs a defensible, privacy-respecting summary. **How:** Run `PURVIRM-Report.ps1` (read-only) and compare the rollup to the portal Alerts/Cases dashboards. **Pass:** The rollup (counts by severity/status over the window) reconciles with the portal, with no identity exposure beyond what the report is authorized to show. **Fail:** Rollup diverges materially from the portal → the portal dashboards are authoritative; reconcile before reporting.

Exit criteria (all must be true before Expand)

- Role separation clean; no conflicting combinations (Gate 1)
- Anonymization ON (Gate 2)
- Indicators/connectors/MDE ready (Gate 3)
- Three policies On + healthy, pilot-scoped (Gate 4)
- Analytics reviewed (Gate 5)
- Sanctioned test → scored alert (Gate 6)
- Alert → audited case (Gate 7)
- HR/legal hand-off confirmed (Gate 8)
- Reporting reconciles with portal (Gate 9)

Troubleshooting — Microsoft Purview Insider Risk Management

Symptom → likely cause → fix, for the failure modes you actually hit deploying and operating IRM. Work top-down; most "IRM isn't working" reports are a missing **trigger**, a disabled **indicator**, or a **licensing/role** gap — not a broken product. When a capability seems absent, **verify it against your licensing/tenant** before assuming a bug (IRM is plan-gated and the portal evolves).

Insider Risk Management doesn't appear in the portal / Settings won't open

• **Cause:** Missing licence (E5 / E5 Compliance / IRM add-on) or missing IRM role.

• **Fix:** Confirm the licence in the M365 admin center (R1) and that your account is in an **Insider Risk Management** role group (Admins to configure). `PURVIRM-Discovery.ps1` lists role-group membership. Verify capability availability against your licensing/tenant.

A policy is On but produces NO alerts

Work these in order — this is the most common report:

1. **No trigger fired.** A user is only scored after the policy's **triggering event**:

• *Departing user:* the HR connector has **no recent leaver record** for the user (or is stale), and you're not using the Entra account-deletion trigger. Check **Settings** → **Data connectors** for a recent successful upload; run `PURVIRM-Test-Readiness.ps1`.

• *Data leaks:* no **DLP high-severity match** occurred (or no DLP policy is wired as the trigger). Confirm a DLP policy exists and matched.

• *Security policy violations:* no **Defender for Endpoint** alert fired, or MDE isn't connected.

1. **Indicator disabled.** The activity's **indicator** is off under **Settings** → **Policy indicators**. Enable the needed family (Office / Device / MDE).

1. **Device not onboarded.** Device indicators (USB/print/personal-cloud) only fire from **onboarded** devices (R5). Check **Settings** → **Device onboarding**.

1. **Detection window.** The activity fell outside the policy's **activation window / past-activity** timeframe (Settings → Policy timeframes). Widen if appropriate.

1. **User not in scope / unlicensed.** The user isn't in the policy scope (`SG-IRM-Pilot`) or isn't licensed. Add them to scope (`PURVIRM-Set-Scope.ps1`) and confirm licensing.

HR connector shows no / stale data — departing-user detection silently stopped

• **Cause:** Upload job failing, schedule lapsed, or the source export changed shape.

• **Fix:** In **Settings** → **Data connectors** open the HR connector and check the last upload status/time. Re-run the upload; validate the CSV/API schema (resignation/termination dates) matches what Microsoft's connector expects. The upload credential lives in the **connector app**, not in any script. If you have no HR feed at all, switch the departing-user policy to the **Entra account-deletion** trigger (coarser, but works without a connector).

Device indicators never fire even though the user copied files

• **Cause:** Device not onboarded to Purview endpoint (same onboarding as Defender for Endpoint), or the

device indicator family is off, or an unsupported OS.

• **Fix:** Confirm onboarding (**Settings** → **Device onboarding**), enable **Device indicators**

(**Settings** → **Policy indicators**), and verify the OS is supported. `PURVIRM-Test-Readiness.ps1` points you to these checks.

Reviewers see real names when they shouldn't (or "why is everyone anonymized?")

• **Cause:** Anonymization posture mis-set, or a role confusion about who may de-anonymize.

• **Fix: Settings** → **Privacy** must have **"Show anonymized versions of usernames"** selected (ON) —

the default and expected posture. Analysts see the **anonymized** experience; **de-anonymization** is an **Investigator**-level, justified, **audited** action (Auditors can see it in the IRM audit log). If anonymization was turned off, re-enable it unless privacy/legal agreed an exception in writing (Gate 2).

An account can both build policies and unmask identities (separation broken)

• **Cause:** Someone holds a **conflicting** combination (e.g. **Admins + Investigators**), or the

combined **Insider Risk Management** role group was assigned to an operator.

• **Fix:** Run `PURVIRM-Discovery.ps1` — it flags conflicting combinations. In **Settings → Roles &

scopes**, reduce each person to** one **function; remove operators from the combined** Insider Risk Management** group. Treat this as a governance finding, not a convenience (Gate 1).

"Access denied" triaging alerts or opening a case

• **Cause:** Wrong role. Triage/investigation needs **Analysts** (triage) or **Investigators** (deep

case + content). Admins **cannot** see alert/case user activity by design.

• **Fix:** Assign the correct functional role group to the operator — without breaking separation

(don't stack Admin + Investigator on one person).

Alerts are overwhelming / lots of false positives in the pilot

• **Cause:** Thresholds too sensitive, no exclusions, or scope too broad for a first pilot.

• **Fix:** This is why you **pilot with analytics and a small scope first**. Tune **intelligent

detection **settings, add file-type/domain** exclusions **(recording why), and keep scope at** `SG-IRM-Pilot` **until noise is acceptable. Set a noisy policy** Off**, tune, and re-pilot — don't expand scope to "average out" the noise.

Analytics shows nothing / won't run

- **Cause:** Analytics not enabled, insufficient licence, or too little activity yet.
- **Fix:** Enable and **run the scan** under **Insider Risk Management** → **Analytics**; confirm licensing.

Analytics is aggregate and needs no policy — if it still returns nothing, allow more time for activity to accumulate and verify audit ingestion is on.

Security-policy-violation policy never triggers

- **Cause: Microsoft Defender for Endpoint** isn't connected, so its alerts can't act as the trigger

and indicator source.

- **Fix:** Enable the MDE connection/integration and confirm MDE indicators are on

(`PURVIRM-Test-Readiness.ps1` reminds you). Verify MDE licensing/availability in your tenant.

`Get-InsiderRiskPolicy` / IRM cmdlets aren't recognized

- **Cause:** IRM authoring is **primarily portal-based**; the cmdlet surface is limited and

tenant/version-dependent.

- **Fix:** Manage policies in **purview.microsoft.com** → **Insider Risk Management** → **Policies**. The

scripts here deliberately use PowerShell for **readiness, role/scope verification, and reporting** — not to invent an authoring path. `PURVIRM-Set-PolicyFromTemplate.ps1 -WhatIf` prints the exact plan to apply in the portal.

`PURVIRM-Report.ps1` returns no records

- **Cause:** Unified audit-log ingestion off, window too short, or no IRM activity yet.
- **Fix:** Enable audit ingestion (`PURVIRM-Test-Readiness.ps1`), widen `-DaysBack`, and remember the

portal Alerts/Cases dashboards are authoritative — the CSV is a summary aid, not the source of truth (Gate 9).

Connect-IPPSSession / Connect-MgGraph fails

- **Cause:** Module not installed, modern-auth/MFA blocked, or wrong account.
- **Fix:** Install **ExchangeOnlineManagement** and **Microsoft.Graph**, sign in with an **MFA-capable**

admin, and ensure Security & Compliance PowerShell is reachable. See `global-requirements-purview.md` §3.

When to stop and escalate to HR/legal (not troubleshoot)

- You have a **real** confirmed case and need a determination or disciplinary decision → that is

HR/legal's, not an administrator's, and not a "fix" in this guide.

- You're unsure whether you may **enable monitoring** or **de-anonymize** a user → stop and get the

lawful-basis / privacy decision first (R9). The technical method is here; the determination is not.

Best Practices — Microsoft Purview Insider Risk Management

Operating principles that keep an IRM program **effective, defensible, and privacy-respecting**. They reflect the three non-negotiables: privacy by design, strict role separation, and determinations that belong to HR/legal.

Privacy first — always

- **Keep anonymization ON.** Reviewers see pseudonymized identities by default. De-anonymization is a

justified, role-gated, audited exception — never a routine step, never the administrator's call.

- **Scope to the minimum.** Only put people in a policy's scope when there is a reason. Broad,

everyone-in-scope policies are both noisy and hard to justify to privacy/legal.

- **Least data, least reveal.** Prefer analytics (aggregate, no names) to size the program; reveal

identity only when a case genuinely requires it.

- **Document the privacy decisions** (anonymization posture, who may de-anonymize, on what basis) and

keep them current with privacy/legal.

Role separation — enforce it, then watch it

- **One function per person.** Admins configure; Analysts triage; Investigators go deep; Auditors watch

the reviewers. Do **not** concentrate roles, and do **not** assign the combined **Insider Risk Management** role group to operators.

- **Independent audit.** Assign **Auditors** who are **not** Admins/Analysts/Investigators, and have

them review the IRM audit log on a schedule — especially every **de-anonymization**.

- **Re-verify after every change.** Re-run `PURVIRM-Discovery.ps1` after any role change; treat a

conflicting combination as an incident, not a convenience.

Determinations stay with HR/legal

- **IRM produces evidence, not verdicts.** An alert or a case is a signal and an audited trail. Whether

it reflects misconduct, and what happens next, is an **HR/legal/privacy determination**.

- **Route, don't rule.** Use case actions to route evidence (notification, eDiscovery, Communication

Compliance, resolve). The employment decision is made by the people authorized to make it.

- **Engage before you enable.** Confirm the lawful basis / notice / consultation for your

jurisdiction(s) **before** switching a policy on. Applicability is a legal determination.

Pilot and tune before you rely

• **Analytics first.** Run Insider Risk analytics before scoping anyone — it is aggregate and needs no policy.

• **Pilot scope, then expand.** Start every policy at `SG-IRM-Pilot`, tune thresholds and exclusions against real activity, and expand **group-by-group** only after the gates pass.

• **Tune out noise deliberately.** Use file-type/domain exclusions and the intelligent-detection settings to cut false positives — but record why, so exclusions don't quietly blind the program.

Detection hygiene

• **Enable only the indicators you need**, and make sure their prerequisites are met (device onboarding for device indicators; MDE connection for security-policy violations; HR connector for departing-user triggers).

• **Keep the HR connector fresh.** A stale leaver feed means departing-user detection silently stops. Monitor connector health (`PURVIRM-Test-Readiness.ps1`) and alert on failed uploads.

• **Prefer the HR trigger over account-deletion** where possible — it detects theft **before** the account is gone, not after.

• **Use priority user groups sparingly** and with HR/legal — membership in a "priority" group is itself sensitive.

Operations and evidence integrity

• **Triage promptly and consistently.** A backlog of un-triaged alerts undermines both effectiveness and fairness. Agree SLAs for triage with the team.

• **Never delete cases/audit records to tidy up.** They are the defensible, HR/legal-facing trail. Retention/disposition of IRM records is a **records/legal determination**.

• **Report without over-exposing.** Leadership rollups should show counts/severity/trends (`PURVIRM-Report.ps1`) — not identities — unless the audience is authorized.

Change control and safety

• **All policy/scope changes go through change control**, previewed with `-WhatIf` where a script supports it.

• **No secrets in automation.** Scripts authenticate interactively (`Connect-IPPSSession` / `Connect-MgGraph`); the HR-connector credential lives in the connector app, never in code.

• **Verify against your licensing/tenant.** IRM capabilities are plan-gated and the portal evolves — confirm availability rather than assuming, and re-check when Microsoft ships changes.

Fit with the rest of Purview

• **IRM + DLP.** Data-leak policies can trigger on DLP matches; Adaptive Protection can let IRM risk levels drive dynamic DLP/Conditional Access (verify licensing/availability).

• **IRM + Communication Compliance / eDiscovery.** Case actions can escalate into these workflows — keep the role separation consistent across all of them.

• **IRM + audit.** The unified audit log records IRM admin/reviewer activity; keep audit logging on and use it as independent corroboration.

Deliverables Summary — Microsoft Purview Insider Risk Management

Everything included in this solution, and what each piece is for.

Documentation

Document	Purpose
Solution Overview (`01-solution-overview.md`)	What IRM delivers, the HR/privacy sensitivity, the model (policies, indicators, triggers, connectors, alerts→cases), and the guardrails.
Requirements (`02-requirements.md`)	IRM-specific prerequisites — licensing, the role groups + strict separation, anonymization posture, indicators, endpoint/HR/physical connectors, priority groups, HR/legal engagement + lawful basis, pilot/change control.
Implementation (`03-implementation.md`)	Ordered steps: guardrails and role separation **first**, then indicators, policies from templates, connectors, analytics/pilot, validate, expand — with pass/fail gates and rollback.
Testing & Validation (`05-testing.md`)	Nine pass/fail gates from role separation and anonymization through a sanctioned test alert → audited case and the HR/legal hand-off.
Troubleshooting (`06-troubleshooting.md`)	The common IRM failure modes (no alerts, stale HR connector, device indicators not firing, role/permission issues, anonymization confusion) and how to resolve them.
Best Practices (`07-best-practices.md`)	Privacy-first, role-separation, determinations-with-HR/legal, pilot-and-tune, detection hygiene, and evidence-integrity guidance.
Executive Summary (`executive-summary.md`)	One-page business framing for decision-makers.

PowerShell tools (5)

All tools are **read-only or `-WhatIf` by default**, authenticate **interactively** (no credentials in code), and use **Security & Compliance PowerShell** (`Connect-IPPSSession`), **Exchange Online** (`Connect-ExchangeOnline`, for role groups), and/or **Microsoft Graph** (`Connect-MgGraph`). IRM policy *authoring* is a portal action; these tools handle readiness, verification, scoping, and reporting.

Script	Type	What it does
`PURVIRM-Discovery.ps1`	Read-only	IRM readiness + **role-separation** + **privacy-settings** assessment: inventories the IRM role groups and their membership, flags any conflicting combinations, reports policy/indicator presence where readable, and prompts to confirm the anonymization posture in-portal.
`PURVIRM-Set-PolicyFromTemplate.ps1`	`-WhatIf` default	Policy-from-template **configuration helper**: validates that a chosen template's prerequisites (roles, indicators, trigger source, anonymization) are in place and prints the exact intended policy configuration/plan to apply in the portal; any write path is gated behind `-Commit` and flagged "verify availability in your tenant".
`PURVIRM-Test-Readiness.ps1`	Read-only	**Connector / indicator readiness checker**: reports audit-log ingestion, whether device indicators are enabled (and points to device onboarding), HR-connector presence/freshness where readable, and licensing/integration signals.

Script	Type	What it does
`PURVIRM-Report.ps1`	Read-only	**Alert / case rollup report**: summarizes IRM activity readable from the unified audit log (by type/severity/time) to CSV for a leadership rollup; notes the portal Alerts/Cases dashboards as authoritative.
`PURVIRM-Set-Scope.ps1`	`-WhatIf` default	**Scope / config helper**: previews and (with `-WhatIf:$false`) applies membership changes to the IRM pilot/scope group so expansion stays deliberate and reversible.

Named objects (verbatim — used across docs, scripts, and tests)

- **Pilot scope group:** `SG-IRM-Pilot`
- **Priority user groups (if used):** `PUG-Executives`, `PUG-Privileged-Admins`
- **Policies:**
- `IRM-DepartingUser-DataTheft` — *Data theft by departing users*
- `IRM-DataLeaks-General` — *Data leaks*
- `IRM-SecurityPolicyViolations` — *Security policy violations*
- **Role groups (separation):** Insider Risk Management **Admins / Analysts / Investigators / Auditors **(avoid the combined** Insider Risk Management** group for operators)

What this solution deliberately does NOT do

- It does **not** make investigative or disciplinary **determinations** — those are HR/legal's.
- It does **not** disable anonymization or concentrate roles for convenience.
- It does **not** invent portal paths or cmdlets — where IRM authoring is portal-only, the tools stop at readiness/validation and say so.
- It does **not** decide your **lawful basis** for monitoring — that is a legal determination for your jurisdiction(s).

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

PURVIRM-Discovery.ps1

Purpose: Connects to Exchange Online / Security & Compliance PowerShell and inventories the Insider Risk Management (IRM) role groups and their membership, then flags any account that holds a CONFLICTING COMBINATION of roles (e.g. Admins + Investigators) — the core privacy/separation check. It also reports IRM policy presence where the tenant exposes it, and prompts you to confirm the anonymization (privacy) setting in the portal (that setting is portal-managed). Read-only — it changes nothing. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVIRM-Discovery.ps1

How to run: powershell -ExecutionPolicy Bypass -File .\PURVIRM-Discovery.ps1

PURVIRM-Report.ps1

Purpose: Produces a leadership rollup of IRM activity that is readable from the unified audit log — counts of IRM-related administrative and review events over a time window, grouped by operation — and writes it to CSV. It is a SUMMARY aid: the authoritative alert and case detail lives in the Purview portal (Insider Risk Management -> Alerts / Cases). Read-only — it changes nothing and does not de-anonymize anyone. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVIRM-Report.ps1 -DaysBack 30 -OutputCsv .\PURVIRM-rollup.csv

How to run: powershell -ExecutionPolicy Bypass -File .\PURVIRM-Report.ps1 -DaysBack 30 -OutputCsv .\PURVIRM-rollup.csv

PURVIRM-Set-PolicyFromTemplate.ps1

Purpose: A policy-from-template CONFIGURATION HELPER. IRM policy authoring is done in the Microsoft Purview portal; this script does the safe, checkable part around it: it validates that the chosen template's prerequisites are in place (the right role groups exist, the required indicators/trigger source are ready, anonymization is expected ON) and then prints the EXACT intended policy configuration/plan to apply in the portal. It DEFAULTS TO -WhatIf (plan only) and performs no writes. A -Commit switch is provided only for tenants where a supported IRM policy cmdlet is available; if none is present it explains that authoring is portal-based and stops. It never invents a cmdlet and never stores credentials. HOW TO RUN Plan (default, no changes): powershell -ExecutionPolicy Bypass -File .\PURVIRM-Set-PolicyFromTemplate.ps1 -Template DepartingUserDataTheft Other templates: -Template DataLeaks -Template SecurityPolicyViolations Commit (only where a supported IRM policy cmdlet exists in your tenant): ... -Template DataLeaks -Commit

How to run: Plan (default, no changes): powershell -ExecutionPolicy Bypass -File .\PURVIRM-Set-PolicyFromTemplate.ps1 -Template DepartingUserDataTheft Other templates: -Template DataLeaks -Template SecurityPolicyViolations Commit (only where a supported IRM policy cmdlet exists in your tenant): ... -Template DataLeaks -Commit

PURVIRM-Set-Scope.ps1

Purpose: Manages membership of the IRM pilot/scope group (SG-IRM-Pilot by default) so you can expand an Insider Risk Management rollout from pilot to production a batch at a time, and reversibly.

Because policies are scoped to this group, growing the group expands detection scope without editing each policy. It DEFAULTS TO -WhatIf (preview only) and changes nothing until you re-run with -WhatIf:$false. It only ADDS the members you pass and never retargets policies directly, so expansion stays deliberate. Scoping people into IRM is privacy-sensitive — do it only within the HR/legal-agreed scope. HOW TO RUN Preview (default): powershell -ExecutionPolicy Bypass -File .\PURVIRM-Set-Scope.ps1 -AddMembers user1@contoso.com,user2@contoso.com Apply (after review + change approval + HR/legal-agreed scope): powershell -ExecutionPolicy Bypass -File .\PURVIRM-Set-Scope.ps1 -AddMembers user1@contoso.com -WhatIf:$false

How to run: Preview (default): powershell -ExecutionPolicy Bypass -File .\PURVIRM-Set-Scope.ps1 -AddMembers user1@contoso.com,user2@contoso.com Apply (after review + change approval + HR/legal-agreed scope): powershell -ExecutionPolicy Bypass -File .\PURVIRM-Set-Scope.ps1 -AddMembers user1@contoso.com -WhatIf:$false

PURVIRM-Test-Readiness.ps1

Purpose: A readiness checker for the prerequisites that make IRM detections actually fire. It reports whether unified audit-log ingestion is on (IRM signals depend on the audit pipeline), whether a DLP policy exists to trigger data-leak detection, and — as guided portal checks — device onboarding (for device indicators), HR-connector freshness (departing-user trigger), and the Defender for Endpoint connection (security-policy-violation trigger). Read-only — it changes nothing. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVIRM-Test-Readiness.ps1

How to run: powershell -ExecutionPolicy Bypass -File .\PURVIRM-Test-Readiness.ps1